CRONOS

CTF Vulnerability Assessment & Proof of Concept Report

Prepared by	Nikhil Gowda
Target	chronos.local — 192.168.31.242
Environment	Kali Linux and isolated CTF virtual machine
Assessment scope	TCP/22, TCP/80, TCP/8000 and observed web application behavior
Evidence source	Screenshots supplied by the author

Reporting approach: Each discovered port has its own finding table following the supplied sample format. The report separates confirmed observations from hypotheses. No CVE or severity is invented where the screenshots do not prove it.

1. Executive Summary

The Cronos CTF target was identified as **chronos.local (192.168.31.242)**. Nmap evidence shows TCP ports 22, 80, and 8000 open. Browser/source inspection and Burp Suite testing documented an Express-based date endpoint on port 8000. A separate shell screenshot confirms execution as **www-data**; the evidence does not show root access or conclusively identify the initial vulnerability that led to the shell.

2. Scope and Tools

Scope: the intentionally vulnerable Cronos machine in an isolated training network. Tools shown in the supplied evidence: Nmap, web browser/View Source, CyberChef, Burp Suite Repeater, Netcat, and Linux shell utilities.

3. Port Summary

PORT	OBSERVED SERVICE	EVIDENCE-BASED RESULT
22/tcp	OpenSSH 7.6p1 (Ubuntu 4ubuntu0.3)	Open service/version identified; no SSH exploit demonstrated.
80/tcp	Apache httpd 2.4.29 (Ubuntu)	HTTP service/version identified; no specific Apache CVE demonstrated.
8000/tcp	Node.js Express application	Date endpoint observed; error responses captured; www-data shell evidence exists but exact initial exploit is not conclusively linked by these screenshots.

4. Port-by-Port Findings and PoC

Finding A — TCP/22

PORT NO	22/tcp
SERVICE NAME	SSH — OpenSSH
VERSION	OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (as detected by Nmap)
SEVERITY	Informational / exposure observation; no direct vulnerability proven
VULNERABILITY NAME	Exposed SSH Service / Service Enumeration
CVE ID	N/A — not established by supplied evidence
DESCRIPTION	The SSH service was reachable on the target. Exposed SSH increases the attack surface, but the screenshots do not show weak credentials, vulnerable configuration, or successful SSH exploitation.
REMEDIATION	Restrict SSH to trusted sources; use key-based authentication where feasible; disable unused authentication methods; keep the package patched; monitor authentication logs and apply rate limiting.
PROOF OF CONCEPT	The supplied Nmap scan reports 22/tcp open with OpenSSH 7.6p1 Ubuntu 4ubuntu0.3. This confirms service exposure only.

Evidence: Screenshot 02 — Nmap service/version scan.

Finding B — TCP/80

PORT NO	80/tcp
SERVICE NAME	HTTP — Apache web server
VERSION	Apache httpd 2.4.29 (Ubuntu), as detected by Nmap
SEVERITY	Informational / version disclosure observation; exploitability not established
VULNERABILITY NAME	Apache Version Disclosure / Exposed HTTP Service
CVE ID	N/A — no specific CVE confirmed
DESCRIPTION	The HTTP service is reachable and the service scan identifies an Apache version. A version banner may help an assessor research patch status, but the screenshot alone does not prove a vulnerable configuration or exploitable Apache flaw.
REMEDIATION	Verify the installed Ubuntu package and security backports; apply supported security updates; disable unnecessary modules; configure server tokens/signature appropriately; review HTTP headers and web content.
PROOF OF CONCEPT	The supplied Nmap service scan identifies 80/tcp open and reports Apache httpd 2.4.29 (Ubuntu). This is evidence of the service/version, not proof of a specific Apache vulnerability.

Evidence: Screenshot 02 — Nmap service/version scan.

Finding C — TCP/8000

PORT NO	8000/tcp
SERVICE NAME	Node.js / Express web application
VERSION	Nmap identified Node.js Express; exact runtime/version is not shown in the supplied scan
SEVERITY	Needs validation; potential application input-handling issue. Do not assign a confirmed severity from the current evidence alone.
VULNERABILITY NAME	Date Endpoint Input Handling — Suspected, Not Confirmed
CVE ID	N/A — no CVE confirmed by screenshots
DESCRIPTION	The page source contains obfuscated JavaScript that builds a request to /date?format=... on chronos.local:8000. A direct request displayed “Permission Denied”; a Burp request returned HTTP 200 with “Something went wrong.” These results show endpoint behavior, but do not independently prove command injection or another specific flaw.
REMEDIATION	Validate and allowlist format input; use safe date-formatting APIs; never pass user-controlled data to shell commands; return generic client errors and log details server-side; run the service with least privilege; restrict port 8000 to required interfaces.
PROOF OF CONCEPT	Evidence screenshots show: (1) source referencing /date?format=...; (2) direct endpoint response “Permission Denied”; and (3) Burp Suite response HTTP 200 with “Something went wrong.” These are non-destructive observations. The shell screenshot separately confirms www-data execution in the lab, but does not conclusively tie the shell to this endpoint.

Evidence: Screenshots 03–06 and 07 — source, endpoint responses, Burp, and shell identity.

5. Supporting Finding — Web-Application Shell Context

RELATED PORT	Likely web application context; the screenshots do not prove which specific request initiated access
SERVICE NAME	Web application process / www-data account
VERSION	Not applicable
SEVERITY	High impact if confirmed in a real environment; CTF evidence only and no formal severity assigned
VULNERABILITY NAME	Command Execution / Shell Access Evidence — Root Cause Unconfirmed
CVE ID	N/A — not established
DESCRIPTION	A terminal screenshot shows uid=33(www-data) gid=33(www-data) and whoami returning www-data. This confirms a shell operating as the web-server account. It does not prove root access or identify the exact vulnerability used to obtain the shell.
REMEDIATION	Determine and fix the initial entry point; patch the affected application/component; run the service as a dedicated low-privilege account; restrict writable directories and outbound network access; rotate any exposed secrets; review logs and retest.
PROOF OF CONCEPT	The captured shell identity output displays uid=33(www-data) and whoami=www-data. This is the direct evidence of the observed shell context. No root proof is included.

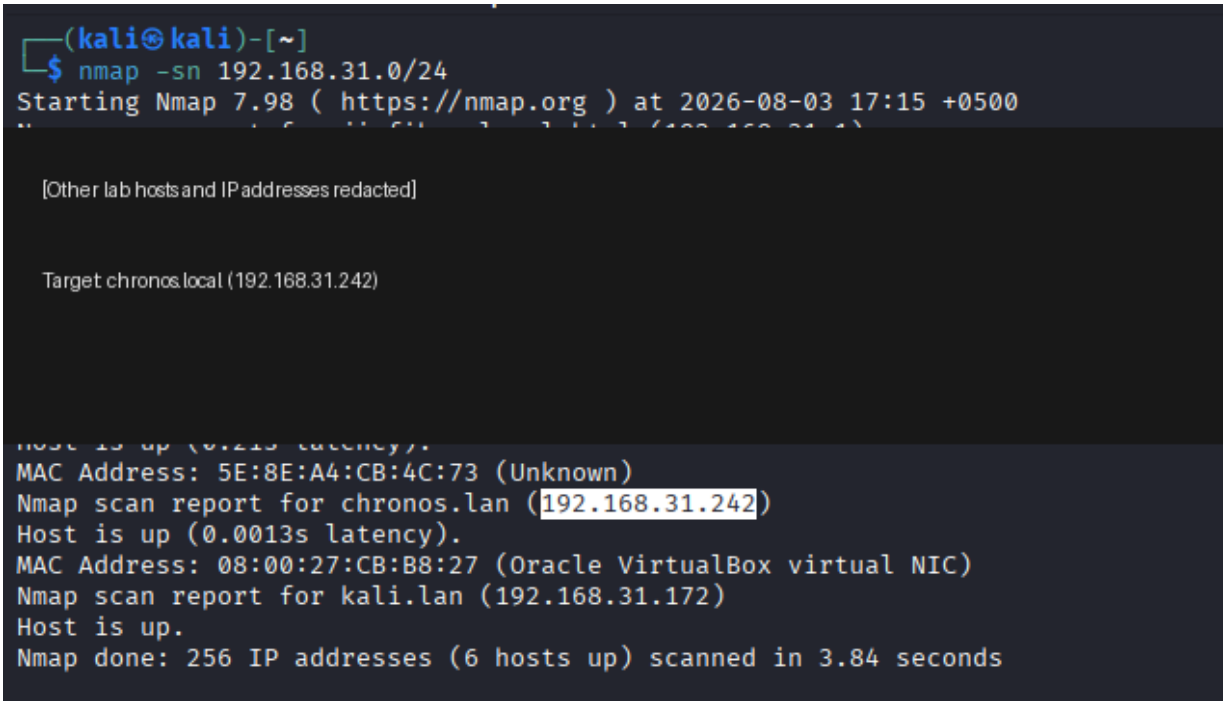
6. Supporting Dependency Observation

COMPONENT	chronos-v2/backend
DEPENDENCY	express-fileupload
VERSION EVIDENCE	package.json lists ^1.1.7-alpha.3
SEVERITY	Unrated pending verification
DESCRIPTION	The supplied screenshot shows the dependency range in package.json. It does not establish the installed version, whether a vulnerable code path is reachable, or a confirmed CVE.
PROOF OF CONCEPT	Screenshot 09 shows the backend package.json dependency entry. Verify lockfile/installed version and vendor advisory applicability before reporting a vulnerability.
REMEDIATION	Inventory actual installed versions, compare against authoritative security advisories, upgrade to a supported fixed version after testing, and rebuild/redeploy dependencies.

7. Screenshot Evidence

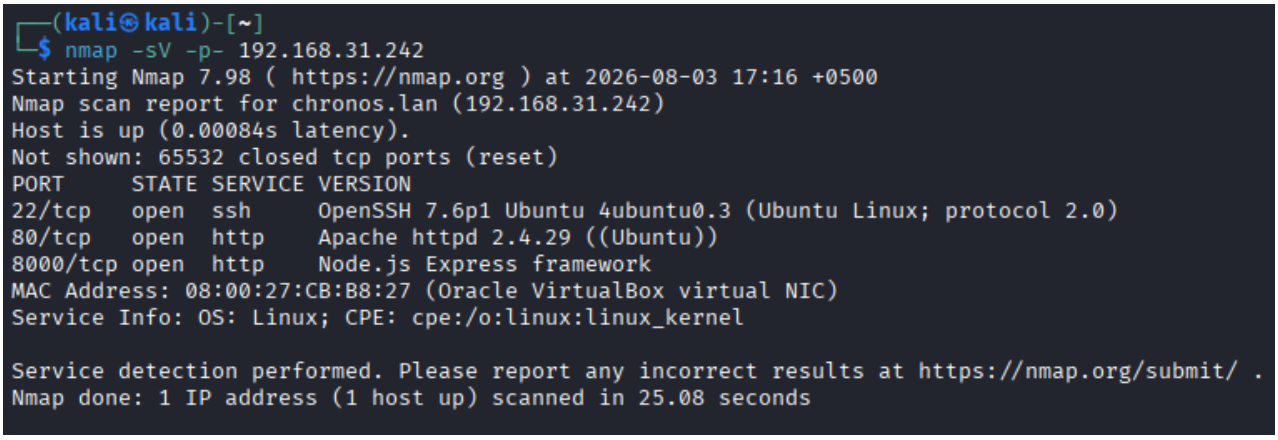
1. Host discovery

The target chronos.local (192.168.31.242) was identified during discovery. Other hosts in the lab subnet are redacted.



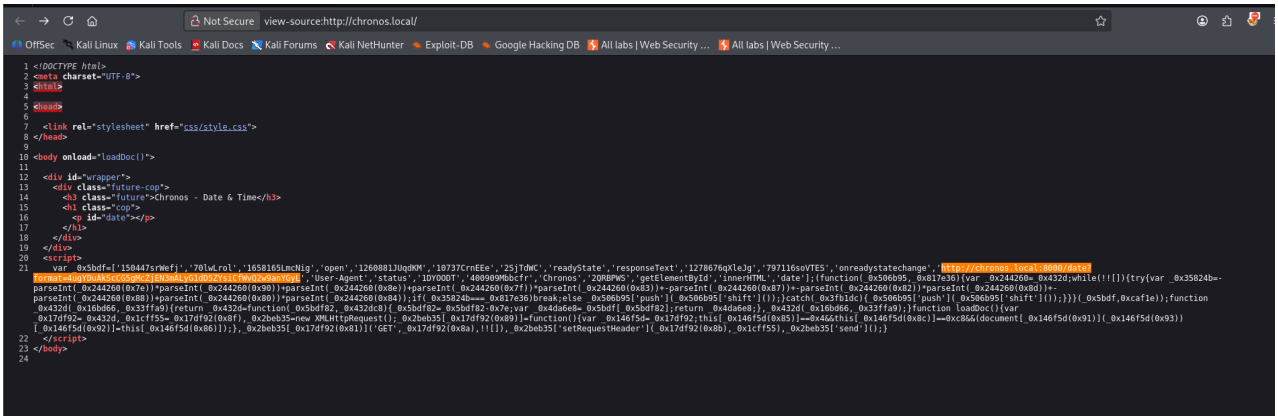
2. Nmap service/version scan

The scan identified TCP/22 OpenSSH 7.6p1, TCP/80 Apache httpd 2.4.29, and TCP/8000 Node.js Express.



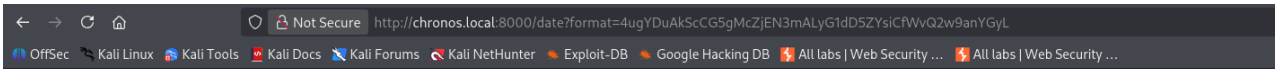
3. JavaScript source inspection

Obfuscated JavaScript references a request to /date?format=... on chronos.local:8000.



4. Endpoint response

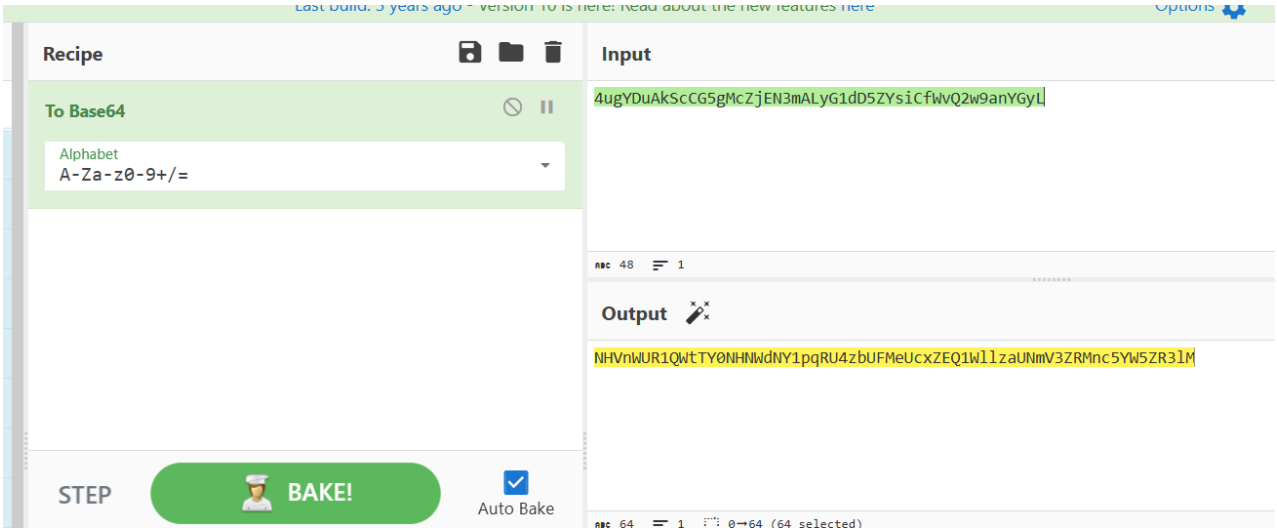
A direct request returned Permission Denied.



Permission Denied

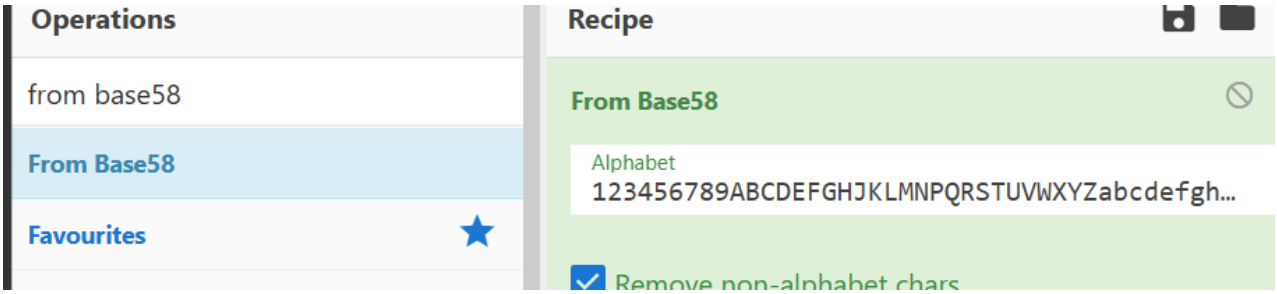
5. Encoding analysis

CyberChef was used to inspect encoded values and the decoded date-format string.



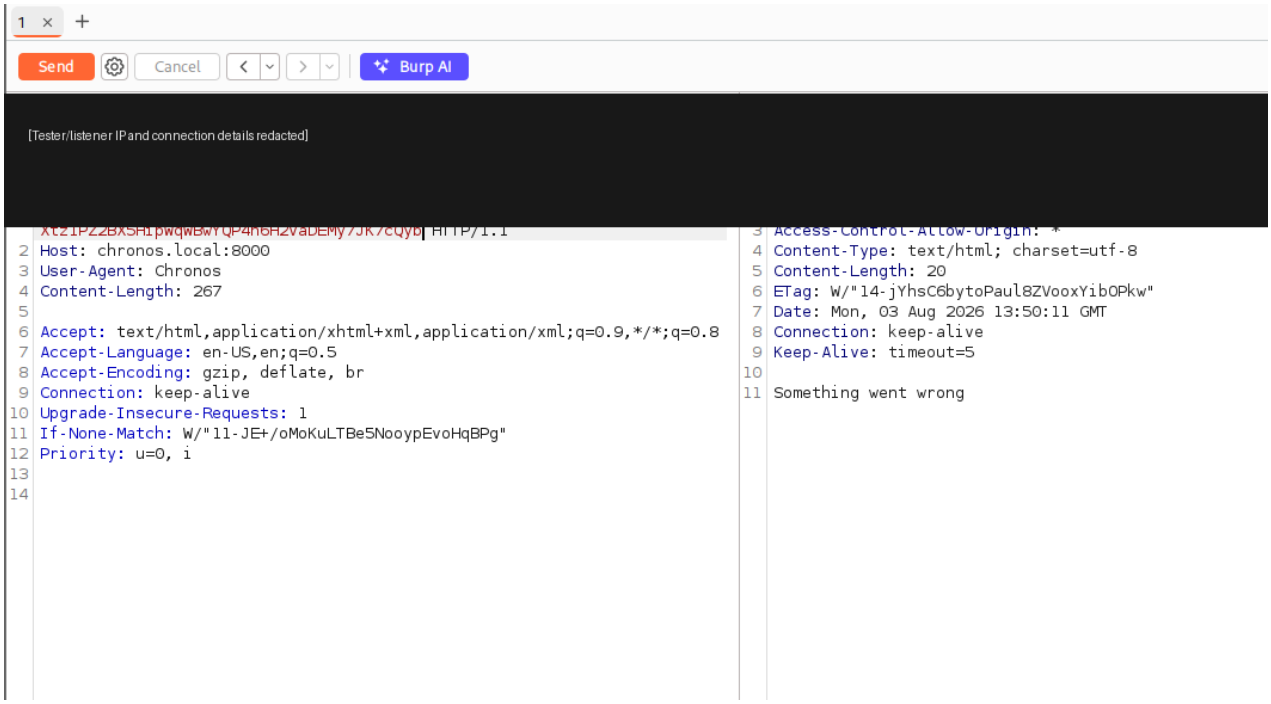
6. Burp Suite request/response

The captured request returned HTTP 200 with the body 'Something went wrong'.



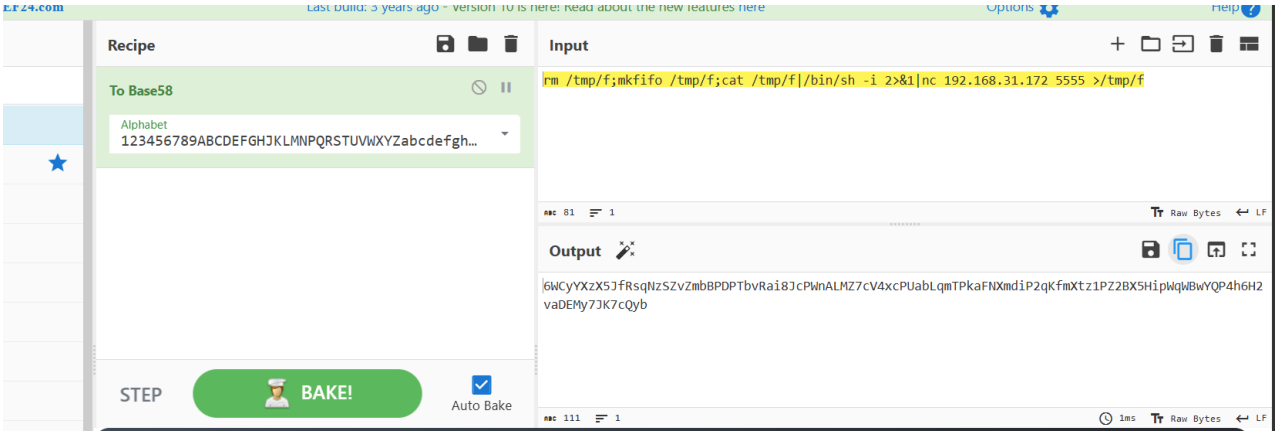
7. Shell identity evidence

The terminal shows uid=33(www-data) and whoami returning www-data.



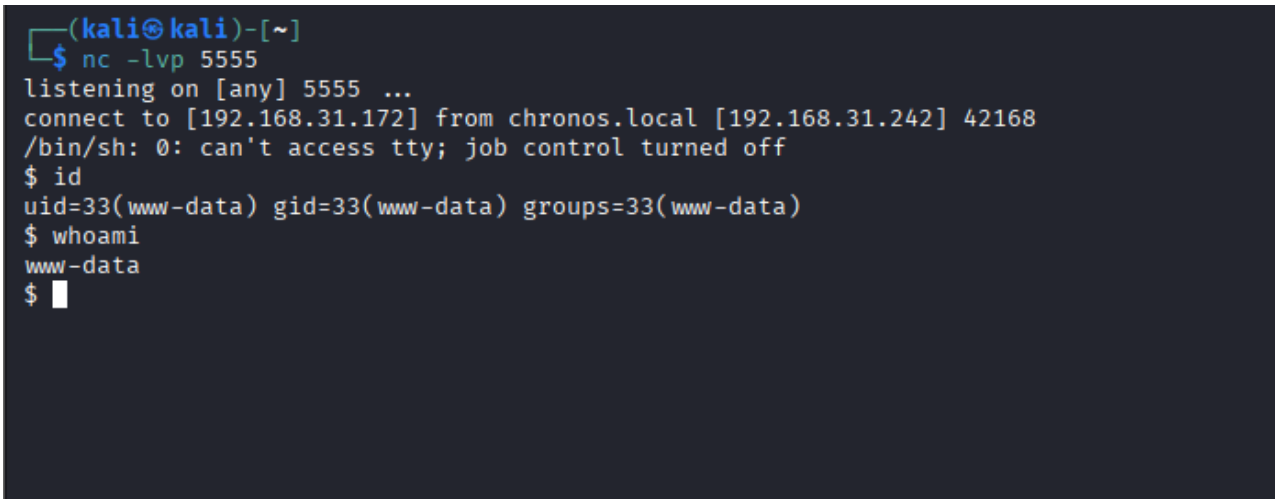
8. Application directory enumeration

The shell was used to inspect /opt and identify chronos and chronos-v2 application directories.



9. Backend dependency evidence

The package.json shown in the screenshot lists express-fileupload ^1.1.7-alpha.3.



8. Conclusion and Limitations

Confirmed by supplied evidence: TCP/22, TCP/80, and TCP/8000 were open; the target served an Express-based application; the date endpoint produced the captured responses; a shell was available as www-data; and the backend manifest contained an express-fileupload version range. Not confirmed by the supplied evidence: a specific SSH/Apache CVE, a definitive command-injection root cause, dependency exploitability, root access, or a CVSS severity. These require further validation before being represented as confirmed vulnerabilities.

9. General Recommendations

- Restrict exposed services to required networks.
- Confirm patch status and dependency versions rather than relying only on banners or version ranges.
- Validate application input and avoid shell execution of user-controlled strings.
- Enforce least privilege and restrict filesystem access for web processes.
- Retest after remediation and keep sanitized evidence with each finding.

10. Disclaimer

This report is for an authorized, isolated CTF/training environment only. The target IP 192.168.31.242 is retained as requested; unrelated lab IPs and tester/listener details are redacted in the host-discovery and shell screenshots. Do not test systems without explicit permission.